
Informe de Pentesting

Actividad A08 — Hacking Ético

Cliente: INSECUR S.A. — Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información — Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta

Estudiante: Lucrecia Concatti
Username TryHackMe: lucre54

Ciclo Académico Vigente

Contents

1	Resumen ejecutivo	2
2	Datos generales	2
3	Pre-pentesting	2
4	Durante: Hallazgos por fase	3
5	Resumen ejecutivo de hallazgos	14
6	Post-pentesting: Recomendaciones	15
7	Protocolo de Contingencia	16
8	Conclusiones	16
9	Anexos	17

1. Resumen ejecutivo

Entre el 02/10/2026 y el 05/10/2026 se realizó una evaluación de penetración sobre tres entornos de laboratorio de TryHackMe (*Pentesting Fundamentals*, *Basic Pentesting* y *RootMe*), en el marco de la Actividad A08 de la cátedra Seguridad Aplicada a Sistemas de Información. Se identificaron **8 hallazgos** (4 críticos, 2 altos y 2 medios), que en conjunto conforman una cadena de ataque completa: desde la enumeración inicial de usuarios y la filtración de información sensible, pasando por un acceso inicial mediante contraseña débil, hasta la escalada total de privilegios a **root** en ambas máquinas Linux evaluadas. Se documenta además una vulnerabilidad crítica conocida (Ghostcat, CVE-2020-1938) presente en la superficie expuesta pero no explotada por no ser necesaria para los objetivos de la sala. Las causas raíz predominantes fueron errores de configuración y manejo inseguro de credenciales, más que vulnerabilidades de software sin parche disponible, por lo que las recomendaciones de la Sección 6 priorizan medidas de *hardening* y gestión de credenciales por sobre el parcheo puntual.

2. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno/a)	Lucrecia Concati
DNI	45.256.542
Username TryHackMe	lucre54
Email institucional	concattilucrecia@uch.edu.ar
Sala de elección (Nivel 2)	RootMe
Branch en GitHub	concatti-lucrecia
Fecha de inicio	02/10/2026
Fecha de cierre	05/10/2026

3. Pre-pentesting

Alcance del trabajo

El alcance de esta intervención comprende únicamente los entornos de laboratorio provistos por la plataforma TryHackMe, correspondientes a las siguientes salas:

- **Pentesting Fundamentals** (núcleo obligatorio): entorno simulado de la empresa ficticia ACME.
- **Basic Pentesting** (núcleo obligatorio): máquina Linux con servicios SSH, HTTP y Samba (*Web App Test*).
- **RootMe** (sala de elección, Nivel 2): máquina Linux con servicio web vulnerable (*HackIT - Home*).

Quedan expresamente **excluidos** del alcance: cualquier sistema fuera de las máquinas asignadas por TryHackMe para cada sala, la infraestructura real de INSECUR S.A. (inexistente, utilizada

solo como marco narrativo), y cualquier sistema de terceros accesible desde la red de laboratorio.

Reglas de Enfrentamiento (ROE)

Horarios: las pruebas se realizaron exclusivamente dentro de las sesiones de laboratorio habilitadas por la cátedra, con la máquina virtual (VPN de TryHackMe) activa y el tiempo de vida de cada *lab machine* controlado por la propia plataforma.

Técnicas prohibidas: no se realizaron ataques de denegación de servicio (DoS) sostenidos, fuerza bruta indiscriminada fuera de lo estrictamente necesario para la sala, ni intentos de pivoteo hacia redes fuera del rango asignado por TryHackMe.

Límites de tráfico: los escaneos de puertos se realizaron con `nmap` en modo moderado (`-T4`), evitando saturar el enlace VPN; la enumeración de directorios web se acotó a diccionarios estándar (`dirb/common.txt`).

Notificación ante incidentes: cualquier comportamiento anómalo del laboratorio (caída de la VPN, máquina inaccesible, reinicio inesperado) se gestionó reconectando según las herramientas provistas por TryHackMe, sin requerir escalado al docente en esta instancia.

Autorización

Declaro que las actividades descriptas en este informe se realizaron únicamente sobre los entornos de laboratorio provistos por TryHackMe, bajo autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH), en el marco de la Actividad A08. Ninguna técnica aquí documentada fue aplicada contra sistemas reales o de terceros sin autorización.

Metodología utilizada

Se siguió un enfoque alineado a **PTES (Penetration Testing Execution Standard)**, adaptado a las cuatro fases propuestas por la guía de cátedra: *Reconocimiento*, *Escaneo*, *Explotación* y *Post-explotación*. Se eligió PTES por ser un estándar ampliamente adoptado en la industria, con un flujo de trabajo claro y iterativo que facilita la trazabilidad de cada hallazgo desde su detección hasta su remediación, y porque se corresponde directamente con la estructura de evidencias solicitada por la cátedra (carpetas `reconocimiento/`, `escaneo/`, `explotacion/`, `post/`).

4. Durante: Hallazgos por fase

H-01 — Enumeración de usuarios vía sesión nula SMB (RID cycling)

Campo	Valor
ID del hallazgo	H-01
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación

Descripción	Durante el escaneo de la sala <i>Basic Pentesting</i> , enum4linux permitió enumerar usuarios del sistema mediante sesión nula (sin credenciales) utilizando <i>RID cycling</i> sobre el servicio Samba, revelando las cuentas locales kay , jan y ubuntu . Esta información resultó clave para orientar los ataques de fuerza bruta dirigidos documentados en H-03.
Componente afectado	Servicio Samba (SMB)
Categoría (OWASP / CWE)	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
CVE (si aplica)	No aplica (error de configuración)
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/escaneo/17_escaneo_enumeracion_smb_usuarios_H-07.png
Herramienta utilizada	enum4linux
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Deshabilitar sesiones nulas/anónimas en Samba (restrict anonymous); exigir autenticación para listar usuarios y recursos compartidos; segmentar el servicio SMB de redes no confiables.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

```

kali@kali:~$ enum4linux -u 10.67.185.123 --local-auth --local-auth=0
enum4linux v1.0.1
( Users on 10.67.185.123 via RID cycling (RIDs: 500-510,1000-1050) )
[+] Found new SID:
S-1-22-1
[+] Found new SID:
S-1-5-32
[+] Found new SID:
S-1-5-32
[+] Found new SID:
S-1-5-32
[+] Found new SID:
S-1-5-32
[+] Found new SID:
S-1-5-32
[*] Enumerating users using SID S-1-22-1 and login username '', password ''
S-1-22-1-1000 Unix User/kay (Local User)
S-1-22-1-1001 Unix User/jan (Local User)
S-1-22-1-1002 Unix User/ubuntu (Local User)
[*] Enumerating users using SID S-1-5-32 and login username '', password ''
S-1-5-32-544 BUILTIN\Administrators (Local Group)
S-1-5-32-545 BUILTIN\Users (Local Group)
S-1-5-32-546 BUILTIN\Guests (Local Group)
S-1-5-32-547 BUILTIN\Power Users (Local Group)
S-1-5-32-548 BUILTIN\Account Operators (Local Group)
S-1-5-32-549 BUILTIN\Server Operators (Local Group)
S-1-5-32-550 BUILTIN\Print Operators (Local Group)
[*] Enumerating users using SID S-1-5-21-2B3222168-2088227510-351223869 and login username '', password ''
S-1-5-21-2B3222168-2088227510-351223869-901 BASIC2\nobody (Local User)
S-1-5-21-2B3222168-2088227510-351223869-513 BASIC2\None (Domain Group)
( Getting printer info for 10.67.185.123 )
no printers returned.
enum4linux complete on Sun Oct 4 13:34:02 2026
kali@kali:~$

```

Figure 1: Enumeración de usuarios vía sesión nula SMB con **enum4linux** (H-01).

H-02 — Divulgación de información sensible en directorio `/development/` expuesto

Campo	Valor
ID del hallazgo	H-02
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	La enumeración de directorios web con gobuster reveló un directorio <code>/development/</code> accesible sin autenticación, con los archivos <code>dev.txt</code> y <code>j.txt</code> . Estos exponen comunicación interna del equipo (versión de software en uso, Struts 2.5.12) y, de forma crítica, una nota de un administrador (K) advirtiéndole a jan que había logrado crackear su contraseña tras auditar <code>/etc/shadow</code> — confirmando de antemano la debilidad de esa credencial, explotada luego en H-03.
Componente afectado	Servidor web Apache — directorio <code>/development/</code>
Categoría (OWASP / CWE)	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☒ Medio ☐ Alto ☐ Crítico
Evidencia (captura / comando)	<code>evidencias/escaneo/14_escaneo_enumeracion_web_directorio_development.</code> <code>evidencias/escaneo/15_escaneo_enumeracion_web_dev.txt_H-05.png,</code> <code>evidencias/escaneo/16_escaneo_enumeracion_web_j.txt_H-06.png</code>
Herramienta utilizada	gobuster (<code>dirb/common.txt</code>), navegador web
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Eliminar archivos de desarrollo y notas internas del entorno productivo; restringir el acceso a directorios no destinados al público mediante autenticación o reglas del servidor web; incorporar revisión de contenido expuesto al proceso de despliegue.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

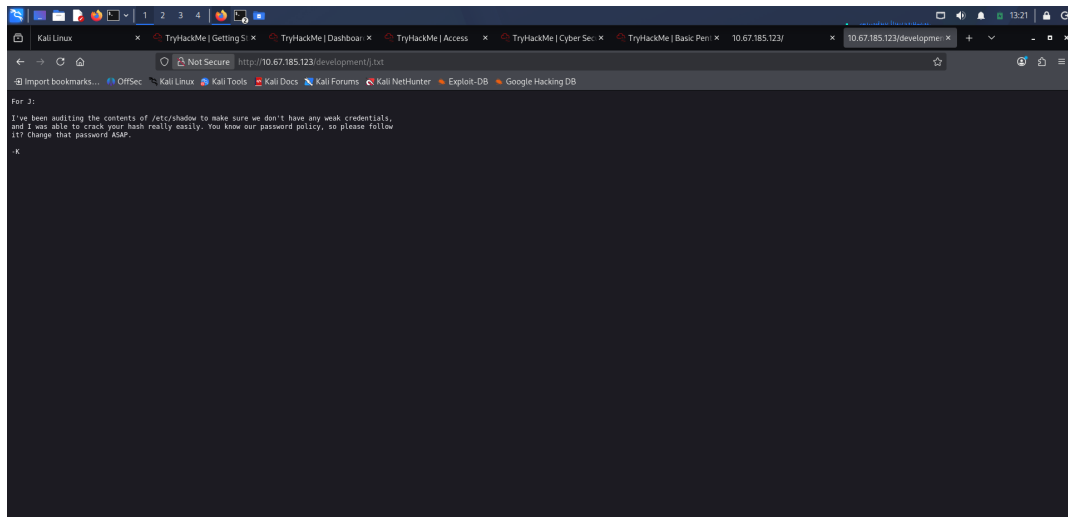


Figure 2: Nota interna hallada en `/development/j.txt`, confirmando la contraseña débil de `jan` (H-02).

H-03 — Contraseña SSH débil del usuario `jan` (crackeada por diccionario)

Campo	Valor
ID del hallazgo	H-03
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	Con el usuario <code>jan</code> obtenido en H-01, se ejecutó un ataque de fuerza bruta dirigido con <code>hydra</code> contra el servicio SSH usando el diccionario <code>rockyou.txt</code> . La contraseña fue hallada en pocos minutos, confirmando la debilidad anticipada en H-02, y constituyó el vector de acceso inicial a la máquina (previo a la obtención de la clave de <code>key</code> documentada en H-04).
Componente afectado	Servicio SSH (OpenSSH) — cuenta <code>jan</code>
Categoría (OWASP / CWE)	CWE-521: Weak Password Requirements
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	<code>evidencias/explotacion/18.basic_pentesting_hydra_credenciales_ssh_H-01.png</code> <code>evidencias/explotacion/19.evidencias_explotacion_H-XX.ssh_jan_H-02.png</code>
Herramienta utilizada	<code>hydra</code> , <code>rockyou.txt</code>

Impacto en la Tríada CIA ☒ Confidencialidad ☒ Integridad ☐ Disponibilidad

Salvaguarda propuesta

Exigir contraseñas robustas mediante política técnica (longitud mínima, complejidad); implementar bloqueo tras intentos fallidos (`fail2ban`) o limitar la tasa de intentos; migrar a autenticación exclusivamente por clave pública, deshabilitando `PasswordAuthentication` en SSH.

Riesgo residual tras aplicar ☒ Bajo ☐ Medio ☐ Alto

```

kali@kali:~$ hydra -l jan -P /usr/share/wordlists/rockyou.txt 10.67.185.123 ssh -t 4 -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-04 13:44:29
[ERROR] file for passwords not found: /usr/share/wordlists/rockyou.txt

kali@kali:~$ ls -l /usr/share/wordlists/
total 51M
-rw-r--r-- 1 root root 25 Jun 16 18:29 dirb -> /usr/share/dirb/wordlists
-rw-r--r-- 1 root root 38 Jun 16 18:29 dirbuster -> /usr/share/dirbuster/wordlists
-rw-r--r-- 1 root root 35 Jun 16 18:29 dmnap.txt -> /usr/share/dmnap/wordlist.TLds.txt
-rw-r--r-- 1 root root 41 Jun 16 18:29 fasttrack.lst -> /usr/share/fasttrack/wordlist.txt
-rw-r--r-- 1 root root 45 Jun 16 18:29 fern-wifi -> /usr/share/fern-wifi-cracker/extra/wordlists
-rw-r--r-- 1 root root 26 Jun 16 18:29 john.lst -> /usr/share/john/password.lst
-rw-r--r-- 1 root root 27 Jun 16 18:29 legion -> /usr/share/legion/wordlists
-rw-r--r-- 1 root root 46 Jun 16 18:29 metasploit -> /usr/share/metasploit-framework/data/wordlists
-rw-r--r-- 1 root root 43 Jun 16 18:29 nmap.lst -> /usr/share/nmap/nselib/data/passwords.lst
-rw-r--r-- 1 root root 518 May 7 06:16 nmap.lst -> /usr/share/nmap/nselib/data/passwords.lst
-rw-r--r-- 1 root root 39 Jun 16 18:29 sqlmap.txt -> /usr/share/sqlmap/data/txt/wordlist.txt
-rw-r--r-- 1 root root 25 Jun 16 18:29 wifid -> /usr/share/wifid/wordlist
-rw-r--r-- 1 root root 37 Jun 16 18:29 wifile.lst -> /usr/share/wifile/wordlist-probable.txt

kali@kali:~$ cat /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:
kali@kali:~$ ls -l /usr/share/wordlists/rockyou
-rw-r--r-- 1 root root 134M May 7 06:16 /usr/share/wordlists/rockyou.txt
-rw-r--r-- 1 root root 51M May 7 06:16 /usr/share/wordlists/rockyou.txt.gz

kali@kali:~$ hydra -l jan -P /usr/share/wordlists/rockyou.txt 10.67.185.123 ssh -t 4 -f
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-10-04 13:48:55
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (1:1/p14344399), -3586180 tries per task
[STATUS] 61.00 tries/min, 61 tries in 00:01h, 14344398 to do in 3919:14h, 4 active
[STATUS] 55.00 tries/min, 165 tries in 00:03h, 14344233 to do in 4346:45h, 4 active
[STATUS] 54.57 tries/min, 382 tries in 00:07h, 14344071 to do in 4308:49h, 4 active
[22][ssh] host: 10.67.185.123 login: jan password: H03
[STATUS] attack finished for 10.67.185.123 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-10-04 14:03:12

kali@kali:~$

```

Figure 3: Ataque de fuerza bruta con hydra sobre SSH, contraseña de `jan` hallada (H-03).

H-04 — Clave SSH privada con permisos de lectura pública

Campo	Valor
ID del hallazgo	H-04
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Durante la enumeración local con LinPEAS en la sala <i>Basic Pentesting</i> , se detectó que la clave privada SSH del usuario <code>kay</code> (<code>/home/kay/.ssh/id_rsa</code>) tenía permisos <code>-rw-r--r--</code> , es decir, legible por cualquier usuario del sistema. La clave estaba protegida por passphrase, pero ésta pudo ser obtenida mediante ataque de diccionario fuera de línea con <code>ssh2john</code> y <code>john</code> , permitiendo autenticarse como <code>kay</code> (miembro del grupo <code>sudo</code>).

Componente afectado	Servicio SSH (OpenSSH 8.2p1) — archivo /home/kay/.ssh/id_rsa
Categoría (OWASP / CWE)	CWE-522: Insufficiently Protected Credentials
CVE (si aplica)	No aplica (error de configuración, no vulnerabilidad de software)
CVSS estimado	☐ Bajo ☐ Medio ☒ Alto ☐ Crítico
Evidencia (captura / comando)	evidencias/post/22_postexploitacion_H-03.png (clave expuesta), evidencias/post/24_postexploitacion_H-05.png (crackeo con john)
Herramienta utilizada	LinPEAS, ssh2john, john (rockyou.txt)
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Restringir permisos de la clave privada a 600 (chmod 600 ~/.ssh/id_rsa); rotar la clave comprometida; establecer una passphrase robusta que no figure en diccionarios conocidos; auditar periódicamente permisos de archivos sensibles en /home.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

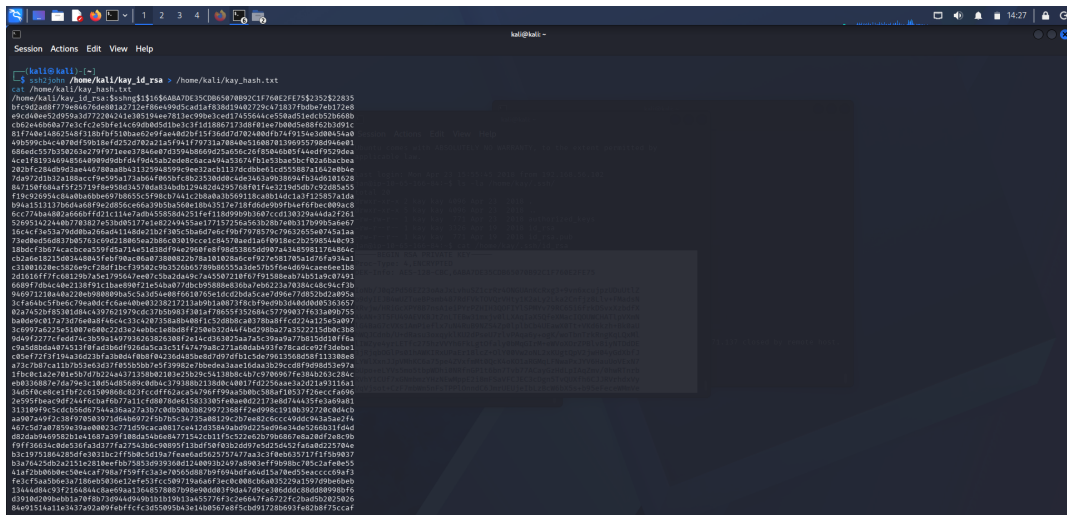
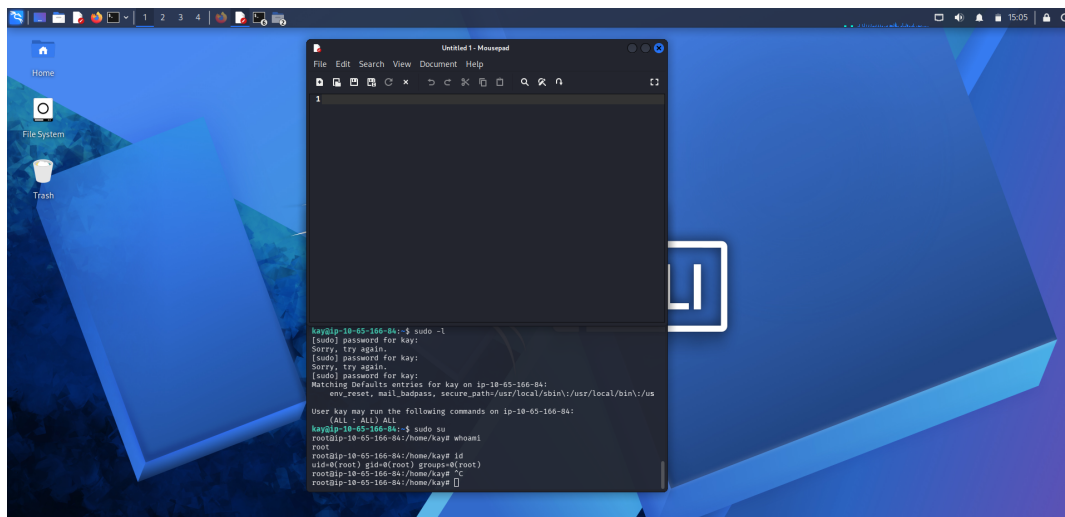


Figure 4: Crackeo de la passphrase de la clave privada de kay con john (H-04).

H-05 — Contraseña de sudo almacenada en archivo de backup legible

Campo	Valor
ID del hallazgo	H-05
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación
Descripción	Una vez autenticada como kay , se encontró en su directorio personal un archivo pass.bak legible que contenía la contraseña de sudo en texto plano. Dado que kay pertenece al grupo sudo con permisos (ALL : ALL) ALL , esta credencial permitió la escalada de privilegios completa hasta el usuario root .
Componente afectado	Archivo /home/kay/pass.bak
Categoría (OWASP / CWE)	CWE-312: Cleartext Storage of Sensitive Information
CVE (si aplica)	No aplica
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	evidencias/post/27_postexplotacion_H-08.png , evidencias/post/29_postexplotacion_H-10.png (escalada a root)
Herramienta utilizada	Acceso de shell como kay , cat , sudo -l , sudo su
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar de forma inmediata todo archivo de backup que contenga credenciales en texto plano; adoptar un gestor de secretos (por ejemplo, Vault o SOPS) para el manejo de contraseñas administrativas; nunca almacenar contraseñas fuera de mecanismos cifrados dedicados.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

Figure 5: Escalada a root con la contraseña de sudo hallada en `pass.bak` (H-05).**H-06 — Carga de archivos sin restricción efectiva de tipo (bypass de filtro de extensión)**

Campo	Valor
ID del hallazgo	H-06
Fase	☐ Reconocimiento ☐ Escaneo ☒ Explotación ☐ Post-explotación
Descripción	En la sala <i>RootMe</i> , la enumeración web con <i>gobuster</i> reveló un directorio <code>/panel/</code> sin autenticación, que exponía un formulario de carga de archivos. Un primer intento de subir una <i>web shell</i> en PHP (<code>shell.php</code>) fue bloqueado por un filtro de tipo <i>blacklist</i> ("PHP não é permitido!"). El filtro, sin embargo, sólo validaba la extensión literal <code>.php</code> : al renombrar el mismo archivo a <code>shell.phtml</code> (extensión que Apache también interpreta como PHP ejecutable), la carga fue aceptada, permitiendo obtener ejecución remota de código (RCE) y una reverse shell como el usuario <code>www-data</code> .
Componente afectado	Formulario de carga en <code>/panel/</code> — Apache httpd 2.4.41 (Ubuntu)
Categoría (OWASP / CWE)	CWE-434: Unrestricted Upload of File with Dangerous Type (OWASP A04:2021 — Insecure Design)
CVE (si aplica)	No aplica (falla de diseño específica de la aplicación)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico

Evidencia (captura / comando)	evidencias/explotacion/37_explotacion_RM-05_filtro_extension_php.png (bloqueo inicial), evidencias/explotacion/39_explotacion_RM-07_bypass_ext (bypass exitoso), evidencias/explotacion/40_explotacion_RM-08_reverse_sh (shell obtenida)
Herramienta utilizada	gobuster, navegador web (carga manual), php-reverse-shell.php (webshells de Kali), netcat (nc -lvnp)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Implementar una lista blanca (<i>whitelist</i>) estricta de extensiones permitidas en lugar de una lista negra; validar el tipo MIME real del archivo (no solo su extensión) inspeccionando el contenido (<i>magic bytes</i>); almacenar los archivos subidos fuera del <i>document root</i> o con permisos de no-ejecución; exigir autenticación para acceder a <code>/panel/</code> .
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

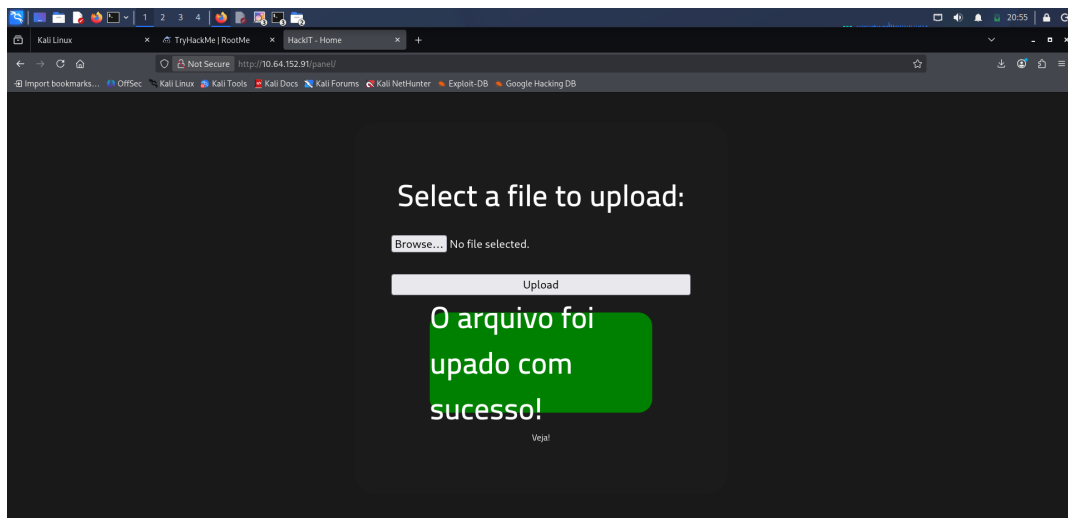


Figure 6: Bypass exitoso del filtro de extensión (`shell.phtml`) en la sala RootMe (H-06).

H-07 — Binario con bit SUID mal configurado (python2.7)

Campo	Valor
ID del hallazgo	H-07
Fase	☐ Reconocimiento ☐ Escaneo ☐ Explotación ☒ Post-explotación

Descripción	Con acceso de shell como <code>www-data</code> en la sala <i>RootMe</i> , la búsqueda de binarios con bit SUID (<code>find / -perm -4000</code>) reveló que <code>/usr/bin/python2.7</code> tenía dicho bit activado, una configuración anómala para un intérprete de propósito general. Esto permitió ejecutar <code>python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'</code> para obtener una shell con privilegios de <code>root</code> de forma inmediata, sin necesidad de explotar ninguna vulnerabilidad de software adicional.
Componente afectado	Binario <code>/usr/bin/python2.7</code>
Categoría (OWASP / CWE)	CWE-269: Improper Privilege Management (OWASP A05:2021 — Security Misconfiguration)
CVE (si aplica)	No aplica (error de configuración del sistema)
CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>evidencias/post/42.postexploitacion_RM-10_suid_python27_encontrado.png</code> <code>evidencias/post/43.postexploitacion_RM-11_escalada_suid_python_root.png</code>
Herramienta utilizada	<code>find -perm -4000</code> , intérprete <code>python2.7</code> (explotación manual)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Eliminar el bit SUID de intérpretes y binarios que no lo requieran (<code>chmod -s /usr/bin/python2.7</code>); realizar auditorías periódicas de binarios SUID/SGID del sistema como parte del proceso de <i>hardening</i> ; aplicar el principio de mínimo privilegio en la configuración de todo el software instalado.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

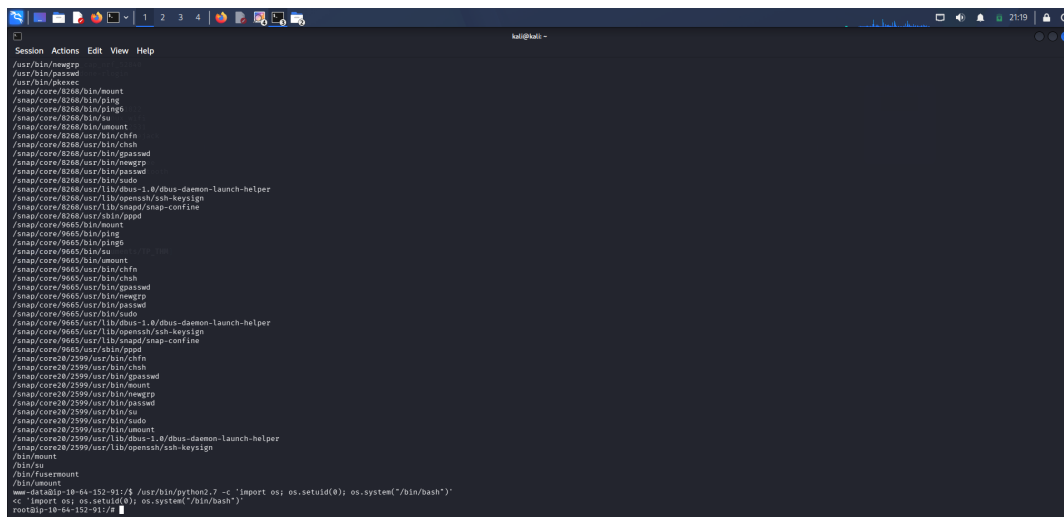


Figure 7: Escalada final a root explotando el bit SUID de python2.7 (H-07).

H-08 — Servicios Tomcat/AJP desactualizados y potencialmente vulnerables a Ghostcat

Campo	Valor
ID del hallazgo	H-08
Fase	☐ Reconocimiento ☒ Escaneo ☐ Explotación ☐ Post-explotación
Descripción	El escaneo inicial con <code>nmap -sC -sV</code> sobre la sala <i>Basic Pentesting</i> reveló, además de SSH/HTTP/SMB, dos puertos adicionales no explotados en este informe: <code>8009/tcp</code> (Apache JServ Protocol — AJP v1.3) y <code>8080/tcp</code> (Apache Tomcat/9.0.7). Esta combinación de versión y conector AJP expuesto corresponde al rango de versiones afectado por Ghostcat (CVE-2020-1938) , una vulnerabilidad que permite lectura (y en ciertas configuraciones escritura) arbitraria de archivos en el servidor a través del conector AJP, sin autenticación. No se procedió a explotarla por no ser necesaria para completar los objetivos de la sala, pero se documenta como hallazgo de superficie de ataque expuesta, siguiendo buenas prácticas profesionales de reportar todo servicio vulnerable identificado durante el escaneo, se haya explotado o no.
Componente afectado	Apache Tomcat 9.0.7 — conector AJP (<code>8009/tcp</code>), interfaz HTTP (<code>8080/tcp</code>)
Categoría (OWASP / CWE)	CWE-918 relacionado / Vulnerabilidad específica: CVE-2020-1938 (Ghostcat) — OWASP A06:2021 (Vulnerable and Outdated Components)
CVE (si aplica)	CVE-2020-1938

CVSS estimado	☐ Bajo ☐ Medio ☐ Alto ☒ Crítico
Evidencia (captura / comando)	<code>evidencias/escaneo/11_escaneo_nmap_inicial_H-01.png</code> (nmap muestra 8009/tcp ajp13 y 8080/tcp Apache Tomcat/9.0.7)
Herramienta utilizada	<code>nmap -sC -sV</code>
Impacto en la Tríada CIA	☒ Confidencialidad ☐ Integridad ☐ Disponibilidad
Salvaguarda propuesta	Actualizar Apache Tomcat a una versión no afectada ($\geq$ 9.0.31, 8.5.51 u 7.0.100 según la rama); deshabilitar el conector AJP si no se utiliza (<code></AJP/></code> en <code>server.xml</code>), o restringirlo a <code>localhost</code> y protegerlo con <code>requiredSecret</code> ; exponer el puerto 8080/8009 únicamente a redes internas confiables.
Riesgo residual tras aplicar	☒ Bajo ☐ Medio ☐ Alto

5. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	4	H-05, H-06, H-07, H-08
Alto	2	H-03, H-04
Medio	2	H-01, H-02
Bajo	0	—
Total	8	H-01 a H-08

Lectura general

La mayoría de los hallazgos identificados corresponden a **errores de configuración, diseño inseguro o manejo deficiente de credenciales**, más que a vulnerabilidades de software con CVE propio: sesiones nulas SMB, información sensible expuesta públicamente, una contraseña débil, permisos excesivos sobre archivos sensibles, almacenamiento de credenciales en texto plano, diseño inseguro de carga de archivos y un binario con privilegios elevados innecesarios. Se observa además una **cadena de ataque completa y realista**: la enumeración SMB (H-01) y la información filtrada en `/development/` (H-02) permitieron anticipar y ejecutar con éxito el acceso inicial por fuerza bruta (H-03), que a su vez habilitó el pivoteo hacia `kay` (H-04) y la escalada final a `root` (H-05). De forma independiente a esta cadena, el escaneo también reveló una superficie de ataque adicional no explotada (H-08, Ghostcat/CVE-2020-1938 sobre Tomcat, único hallazgo con CVE propio). Esto confirma un patrón frecuente en la industria: la configuración insegura y la filtración de información suelen representar un riesgo mayor y más fácil de explotar que las vulnerabilidades conocidas

asociadas a componentes de software desactualizados.

6. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. **(Prioridad crítica)** Eliminar inmediatamente cualquier archivo de backup o configuración que contenga credenciales en texto plano (H-05).
2. **(Prioridad crítica)** Reemplazar la lista negra de extensiones en formularios de carga por una lista blanca estricta, combinada con validación real del tipo de archivo (H-06).
3. **(Prioridad crítica)** Auditar y eliminar bits SUID innecesarios en binarios del sistema, en particular intérpretes de propósito general (H-07).
4. **(Prioridad crítica)** Actualizar Apache Tomcat a una versión no afectada por Ghostcat y deshabilitar o restringir el conector AJP expuesto (H-08).
5. **(Prioridad alta)** Exigir contraseñas robustas y deshabilitar autenticación por contraseña en SSH a favor de claves públicas (H-03).
6. **(Prioridad alta)** Restringir permisos de claves privadas SSH a 600 y rotar toda clave que haya estado expuesta (H-04).
7. **(Prioridad media)** Deshabilitar sesiones nulas/anónimas en el servicio Samba (H-01).
8. **(Prioridad media)** Retirar del entorno productivo cualquier directorio o archivo de desarrollo/notas internas accesible públicamente (H-02).
9. Actualizar los servicios desactualizados detectados durante el escaneo (Apache 2.4.41, kernel Linux 5.15.0-139) a sus últimas versiones estables soportadas.
10. Exigir autenticación en todo panel administrativo expuesto a la red.

Recomendaciones administrativas (políticas y procesos)

1. Establecer una política formal de gestión de credenciales que prohíba explícitamente su almacenamiento en texto plano, con rotación periódica obligatoria.
2. Incorporar capacitación para el equipo de desarrollo sobre validación segura de cargas de archivos (OWASP Top 10, categorías A04 y A05).
3. Definir un proceso trimestral de revisión de permisos de archivos y binarios SUID/SGID (*hardening checklist*).
4. Implementar un proceso formal de gestión de vulnerabilidades, con ventanas de parcheo definidas según criticidad.

7. Protocolo de Contingencia

Escenario de falla

Durante una prueba de carga de archivos sobre un formulario de subida como el identificado en H-06, un archivo malformado o un intento de explotación mal calibrado podría provocar un error fatal no controlado en el proceso de Apache/PHP, interrumpiendo la disponibilidad del servicio web de cara al cliente mientras dure la caída.

Impacto sobre la continuidad del negocio

Se vería afectado el servicio web público de INSECUR S.A., impidiendo el acceso de clientes y empleados a los sistemas alojados en el servidor comprometido. Según la duración de la interrupción y la existencia (o no) de redundancia, el impacto podría oscilar entre 15 minutos de indisponibilidad parcial y varias horas de caída total si no existe un servidor espejo disponible.

Plan de respuesta

1. **Activación:** un sistema de monitoreo activo (*healthchecks* HTTP periódicos) detecta la caída del servicio o códigos de error 5xx sostenidos y dispara una alerta automática al equipo de guardia.
2. **Contención:** en los primeros 15 minutos se aísla el servidor afectado de la red (regla de firewall o apagado de la interfaz), se detiene el proceso comprometido de Apache/PHP y se preservan los logs para análisis forense posterior.
3. **Recuperación:** se restaura el servicio desde un servidor espejo (*failover*) si existe, o se reinstala desde una imagen limpia versionada (Infraestructura como Código) reaplicando la configuración conocida y los últimos backups válidos.
4. **Comunicación:** se notifica de inmediato a la dirección de INSECUR S.A.; si se confirma una brecha con exposición de datos, se evalúa la notificación a clientes afectados y, de corresponder, a las autoridades competentes según la normativa de protección de datos vigente.
5. **Post-mortem:** se documenta la causa raíz, la línea de tiempo completa del incidente y las acciones tomadas; se actualizan los *runbooks* internos y las reglas de monitoreo para prevenir recurrencias.

RTO y RPO estimados

RTO (Recovery Time Objective): 2 horas, considerando la restauración desde servidor espejo o imagen versionada.

RPO (Recovery Point Objective): 1 hora, asumiendo una frecuencia de backups horaria para los componentes críticos.

8. Conclusiones

La evaluación confirmó que, tanto en *Basic Pentesting* como en *RootMe*, el camino más corto hacia el compromiso total del sistema no pasó por vulnerabilidades de software complejas, sino por una sucesión de descuidos de configuración y manejo de credenciales: información expuesta sin necesidad (enumeración SMB, directorios de desarrollo públicos), contraseñas débiles o reutilizadas, archivos de backup con secretos en texto plano y privilegios mal asignados (SUID innecesario). En los ocho

hallazgos documentados, únicamente H-08 corresponde a una vulnerabilidad de software con CVE propio (Ghostcat), y ni siquiera fue necesario explotarla para completar los objetivos de ambas salas — lo cual refuerza la idea de que la superficie de ataque más crítica de un sistema suele estar en cómo se lo configura y opera día a día, no solo en qué tan actualizado está su software. Las recomendaciones de la Sección 6 apuntan a cerrar esa brecha mediante *hardening* sistemático, gestión formal de credenciales y revisión periódica de permisos, más que a un único parche puntual.

9. Anexos

Anexo A — Bitácora de comandos

Se adjuntan en la carpeta `bitacora/` del branch `concatti-lucrecia` los siguientes archivos, uno por sesión de trabajo:

- `bitacora/clase_sala2_basic_pentesting*.txt` — Sala Basic Pentesting.
- `bitacora/clase_sala3_rootme_20261005.txt` — Sala RootMe (sala de elección).

Las credenciales en texto plano fueron redactadas manualmente en ambos archivos previo a su entrega.

Anexo B — Capturas de pantalla

Las evidencias se encuentran en la carpeta `evidencias/` del branch, organizadas en subcarpetas por fase: `reconocimiento/`, `escaneo/`, `explotacion/` y `post/`. Cada archivo sigue la convención `<fase>_<ID>.png`, donde `<ID>` identifica la sala y el paso correspondiente (por ejemplo, RM-08 para el paso 8 de la sala RootMe).

Anexo C — Hashes de credenciales obtenidas

```

1 # Formato: hallazgo_id  descripcion                sha256_hash
2 H-03  password SSH inicial (jan)    9
      eb6835cc95b053818b660bd9fc9f092a0b30cef89c1f0f17f469d5caa0ae617
3 H-04  passphrase clave SSH (kay)    873504
      f0103a88d762191a358f4aa432dbbcf8af64f19dd913d7f8f925191a08
4 H-05  password sudo (kay)            3
      ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57

```

Flags obtenidas (sala RootMe): siguiendo el control de *hash de las flags* de la cátedra, se incluye el hash SHA-256 de cada flag en lugar de su texto plano, evitando exponer valores que circulan en writeups públicos:

```

1 # Formato: flag                sha256_hash
2 user.txt  8
      c8b99b3c6b7a61eb0399dfab5b59c08126f998305c6d05fa44e0cc76cfad5b0
3 root.txt
      ec3faf2a7f12f82b7ab07a19ca777232b3f67ba2c2160e43802ee102a6a9a85c

```

Anexo D — Declaración ética firmada

Declaro que todas las actividades descriptas en este informe se realizaron dentro del alcance autorizado, en entornos controlados (laboratorios de TryHackMe) y con fines exclusivamente académicos, en el marco de la Actividad A08 de la cátedra Seguridad Aplicada a Sistemas de Información.

*Lucrecia Concatti**05/10/2026*

Firma del estudiante

Fecha